

BMS System — Client Questionnaire

Questions for the client, grouped by topic. Usability and product concerns first; security, RBAC, ABAC, and data-integrity questions to be appended after that discussion.

1. Scope & Complexity

Before anything else, we want to make sure the actual size of this request is visible. What's described across the PRDs and the Figma prototype isn't a single app — it's a small platform, made up of the following pieces.

Three distinct product surfaces, not one

- An **Admin/Owner experience** — full visibility across every module (the only one designed so far)
- A **Manager experience** — approvals and department-scoped visibility, distinct from Admin
- An **Employee experience** — self-service only: own decisions, own actions, own expenses
- A **customer sign-up/onboarding experience** — creating a company, choosing a plan, inviting a first team (doesn't exist yet, in any form)

Seven core business modules, each with its own data model, workflows, and screens

- Decisions — logging, search, approval routing
- Approvals — review queue, approve/reject with reasons, history
- Responsibilities — department directory, ownership mapping
- Actions — a 5-stage procurement pipeline, progress tracking, cost variance
- Expenses — manual and action-generated entries, categorization, receipts
- Reports — cross-module analytics and charts
- Settings — account, company, notifications, security, billing, team management

Platform-level systems, invisible in a demo but required for a real product

- Multi-tenant architecture — every company's data fully isolated from every other's
- Authentication — login, MFA, password reset, account activation, session management
- Authorization — role-based (and possibly attribute-based) permissions enforced consistently across every module above
- Notifications — without this, the approval workflow doesn't actually function day to day

- Audit logging — an immutable trail across every action in the system
- File storage — for expense receipts, with retention and access-control rules
- Billing — plan management, usage limits, upgrade/downgrade flows
- A backend API — none of the above exists yet; the current build is frontend-only

Non-functional requirements, rarely visible, always required

- Security posture: encryption at rest/in transit, PII handling, tenant data isolation
- Compliance: audit retention rules, possibly SOC2/GDPR depending on target customers
- Performance: pagination and sorting once real usage data accumulates
- Accessibility: keyboard navigation, screen reader support

We're not raising this to negotiate budget or timeline yet — only so everyone is looking at the same picture before those conversations happen.

2. Specification Conflicts

The two PRD documents provided describe different data models for what's meant to be the same product — different schemas for decisions, different approaches to responsibilities, different levels of detail on actions and expenses. The Figma prototype ended up blending both (some pages match one document, some match the other), which means neither PRD was ever fully implemented end-to-end, and neither is fully "the plan" on its own.

Question: Which document should we treat as authoritative going forward — or do these need to be reconciled into a single spec before more work proceeds?

3. Product Identity & Design

Beyond individual screens, the product currently has no logo, no brand color rationale, and no visual identity distinct from generic SMB dashboard software. We had to build a placeholder text mark just to replace a missing image file referenced in the original project — there was never an actual logo asset anywhere in the project materials.

Question: Do you have existing brand guidelines, a logo, or a design system we should be working from? Or should product identity/branding be treated as its own design phase before more screens get built?

4. User Roles & Experiences

Everything designed and verified so far — across every module — represents a single Administrator's view. The PRD implies at least three roles (Employee, Manager, Admin) and explicitly restricts some actions (like Approvals) to Manager/Admin only. But there is no design anywhere — not in the PRDs, not in Figma — for what an Employee or a Manager actually sees. This isn't a small gap: it likely means most screens in this system need a second (or third) version.

Question: Can you provide or commission designs for the Employee and Manager experiences, or should we propose scoped-down versions of each screen for your review?

5. Customer Onboarding / SMB Signup

If this product is meant to be sold to other small businesses (which the Billing, Upgrade Plan, and Team-invite UI all imply), there needs to be a way for a brand-new company to sign up, create their account, choose a plan, and invite their first users. That flow does not exist anywhere — not in either PRD, not in Figma. Right now, "Login" is the only entry point into the system.

Question: Is self-service signup actually part of the plan, or will new companies be onboarded manually by your team instead? This significantly changes how much needs to be built.

6. Platform

Our recommendation: build BMS as a responsive web application only for the initial release — no native iOS/Android app, no desktop (Electron-style) app. The two workflows that most benefit from "native" — approving a request on the go, photographing a receipt — are both fully achievable on mobile web without the cost of a separate native build.

Question: Does this match your expectations, or is there a specific reason (app-store presence, offline access, push notifications) that requires a native app?

7. Data Lineage / Traceability

The data model already implies a real causal chain: a Decision gets approved → generates an Action → the Action completes → auto-generates an Expense. If enforced and made visible end-to-end, that chain *is* the product's story — a full paper trail for every dollar spent, back to who decided it and why. Right now, nothing in the design surfaces that chain beyond a single link from an expense back to its originating action.

Question: Do you expect a dedicated view where someone can trace this full chain end-to-end (e.g. "show

me everything connected to this decision — who approved it, what action it created, what it ultimately cost, and when") — or is a simple one-way link sufficient?

8. Data Storage & Retention

- Should the system be hosted centrally by you (single shared infrastructure across all customer companies), or self-hosted separately per customer?
- What's the expected backup / disaster-recovery policy?
- Audit logs are meant to be "immutable" — for how long should they be retained? Do they ever get archived or purged?
- Where should uploaded receipt files be stored (a specific cloud provider, on-prem, no preference)?

9. Missing Operational Features

A few features are implied by the data model or the UI but have no defined behavior:

- **Notifications** — nothing tells an approver a request is waiting on them. Without this, the approval workflow may not get used in practice.
- **Budget overrun handling** — Actions show cost variance in red when over budget, but nothing acts on that signal (no alert, no escalation). What should happen when a project goes over budget?
- **Recurring expenses** — the current design treats every expense (including things like monthly rent) as a one-off manual entry. Should recurring expenses be supported, or is manual re-entry acceptable?
- **Approval delegation** — nothing addresses what happens when the person who needs to approve something is unavailable.
- **Editing and deleting records** — as currently specified, decisions, expenses, and responsibility records can be created but never corrected or removed. Is that intentional, or is an edit/delete capability expected?

10. Confirming What's Already Out of Scope

Some features appear to have been intentionally deferred rather than forgotten — for example, automatic receipt scanning (OCR), Slack/Teams notifications, and automated budget-threshold alerts.

Question: Can you confirm these are genuinely out of scope for the first release, and not something you're expecting to see?

11. Assumptions Made So Far, Pending Your Review

A significant portion of the detailed behavior in the current build — specific form fields, what's required to reject a decision, what happens when a list is empty, what an export button actually does — was decided by us while filling gaps that neither PRD nor the Figma prototype addressed. None of these specific decisions have been reviewed or approved by you yet.

Question: Before backend work locks these decisions in permanently, can we walk through them with you to confirm they match what you actually want?

12. Security, RBAC, ABAC, Data Integrity & Confidentiality

(To be added.)